

CAs are intermediate CAs and the untrusted ones are just that, untrusted CAs. However, root CAs don't have to verify that those intermediate CAs are doing their job, they could very well have just been randomly approved. Using the driving license analogy again, how many of you actually check if a bus driver has a license? You just assume that you're travelling in a state-run bus and that the driver's credentials have been verified by some responsible body.

Obviously, there is every chance that the state was just lazy or that the driver paid some money to get the job, despite lacking a license. Given the sheer volume of people that need to be transported (and in effect, Internet traffic) this system works most of the time with only a few bumps and niggles along the way. There will be catastrophic consequences now and then, but overall, the system remains functional enough to not warrant much change. At the most, you create a hulloaloo and kick the driver.

Online doppelgangers

When it comes to HTTPS connections and online transactions, popular websites and banking sites are usually secure and can be trusted, it's the intermediaries that can pose the problems. Lazy Root CAs are effectively handing over all your private online information to something that may not be responsible enough to handle it. This is where almost all identity-theft happens. Hack an irresponsible intermediary and you have all the data you need.

Phishing attacks can and do take place via a similar mechanism. All one really needs to do is find a shady CA, spend a bit of money and voila, you have an SSL certificate that will give your site, no matter what site it is, a nice green HTTPS marker along with a lock icon. If that site just happens to look like your banking site and you just happened to get there, how will you know what's wrong?

The biggest flaw in this system is just that you only see a secure website without knowing who issued the certificate to whom. The SSL route is like a VIP



Not as secure as you would believe

highway, if you have a pass, you can get on. If you know someone who can get you a pass, you're on, whether you're a VIP or not. Browsers such as Firefox take the trouble to maintain their own list of trusted CAs, but what about Chrome, Internet Explorer and the rest? They rely on the OS. Microsoft for example, maintains a list of trusted CAs in a Trusted Root Store in Windows. It's an interesting idea that helps provide the average user with a seemingly secure, seamless system for performing his online interactions. However, this system has one fatal flaw, they're too trusting.

The only way that you can protect yourself from such issues is if you have some way to keep track of the certificates and where they're issued from.

As a simple rule of thumb, if you're banking in India, its certificate would definitely not have been issued in Nigeria.

One of the best tools that helps you do this is Calomel (<http://dgit.in/Z5M9sh>). Of course, even such tools are of no use if you're absolutely careless.

Carelessness

Loopholes in SSL certificates are only one way that hackers can get to know you better. The other is simply because of your laziness. How many times have you used just one password on a dozen different sites? Sure, Google is very secure and there is very little chance of its database getting hacked. But what about on mpgh.net or some other such site?

Two-factor authentication is turning out to be the only way to almost completely guarantee your online safety. It might seem to be cumbersome at first, but it'll be well worth the mental satisfaction. Also, remember that most of the attacks that you read about in the news are not as scary as they seem. You're not so important that a world of hackers will take an interest in you or want to read about what you ate for breakfast or look at your lame pictures. All they really want most of the time is a pool of PCs or information that can be taken advantage off. If you ever get caught in the net, you're just one unfortunate phish among tens of thousands.

